

PORTFOLIO · 26.09 기준

# PORTFOLIO

```
const engineer = "최지현"; // Trusted AI Agent
```

★ Agent System Design

★ End-to-End 서비스

★ Trusted AI

**최지현 | AI를 어디에 넣고, 어디까지 맡길지부터 고민합니다**

AI Agent Engineer · Backend

GitHub [github.com/ttoggle918](https://github.com/ttoggle918) Email [ttoggle918@gmail.com](mailto:ttoggle918@gmail.com) Portfolio [ttoggle918.github.io](https://ttoggle918.github.io)

# ★ ABOUT ME ★

저는 **AI를 어디에 넣고, 어디까지 맡길지**부터 고민하는 AI 에이전트 엔지니어입니다.  
ML 모델링과 NLP 파인튜닝부터 에이전트까지 폭넓게 다뤄 왔습니다.

01

## ★ 구조 설계

Agent System Design

에이전트 하나보다 그 에이전트가 들어갈 시스템 전체를 먼저 그립니다. 어떤 기능이 필요한지 정하고, 에이전트가 맡을 부분과 백엔드·DB가 맡을 부분을 나눈 뒤 설계합니다.  
LangGraph·MCP로 에이전트를 짜는 데서 끝내지 않고 FastAPI·Spring 서버와 DB까지 직접 이어 봤습니다.

02

## ★ 신뢰성

Trusted AI (RAG & Validation)

AI가 틀렸을 때를 대비해, 사람이 근거를 보고 직접 판단할 수 있어야 한다고 생각합니다. 그래서 답에는 원문 근거를 붙였습니다. AI는 비서처럼 자료를 모아 주고, 책임이 따르는 작업은 사람이 직접 해야만 진행되게 했습니다.

03

## ★ 도메인 적응력

End-to-End & Adaptability

보안·무역·채용·제조·보험·금융. 새 분야를 만나면 그 일을 하는 사람의 하루부터 떠올려 보고, 무엇을 확인하는지 찾는 데서 시작합니다.

### CONTENTS

|                              |    |                                       |    |                    |    |                            |    |
|------------------------------|----|---------------------------------------|----|--------------------|----|----------------------------|----|
| About Me                     | 02 | Skill                                 | 03 | Career & Education | 04 | 01 QMesh - 회사 간 에이전트 연결    | 05 |
| 01-1 FinAllQ - 은행            | 06 | 01-2 InsuQ - 보험                       | 08 | 01-3 MaintQ - 제조   | 10 | 02 SecureAI Engine - 코드 보안 | 12 |
| 03 KeyLens · 04 SpendQ · 하네스 | 14 | 05 K-Bridge · 06 KOCRUIT · 07-08 비상교육 | 15 | Future Plans       | 16 | Contact                    | 17 |

## ★ SKILL ★

프로젝트에서 직접 써 본 기술입니다. 핵심 스택은 **파란색**으로 표시했습니다.

### ★ AI 에이전트 · 오케스트레이션

LangGraph

RAG

MCP / FastMCP

A2A Protocol

Claude API

LangChain

Claude Code 멀티 에이전트

Hybrid Search · Reranker

HyDE

pgvector / Qdrant / FAISS

GPT-4o · Gemini

### ★ Backend / Infra

FastAPI (Async)

Spring Boot

PostgreSQL (+pgvector)

MSA

Docker Compose

Redis

SSE · WebSocket

JWT · OAuth2

MySQL · Oracle

AWS EC2 / RDS

GitHub Actions

### ★ ML · NLP · 데이터

SBERT Fine-tuning

HuggingFace

XGBoost

PyTorch

RandomForest · KMeans

KoBERT

Whisper / Pyannote

NER · 개인정보 익명화

### ★ 보안 · 관측성 · 클라이언트

SAST / DAST (OWASP ZAP)

Prometheus · Grafana

Jaeger / OpenTelemetry

AES-256-GCM · Argon2id

CWE / OWASP 매핑

SBOM · NVD CVE

Next.js / React / TS

VSCode Extension

Android (Kotlin·Compose)

# ★ CAREER & EDUCATION ★

● Education ● Career ● Degree · 자격증

2015 ~ 2023

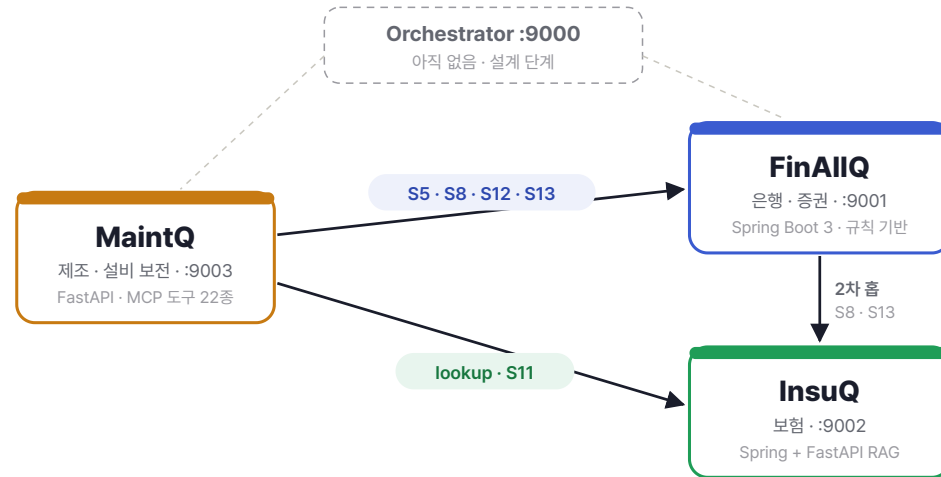
- 2015.03 ~ 2020.02  
**명지대학교 컴퓨터공학과 학사**
  - 데이터베이스 설계 · 자료구조 · 컴퓨터 보안
  - 총장상 (2019.12, TOPCIT 우수 성적)
- 2019.06 ~ 2019.08  
**세코닉스 - 인사팀 인턴**
  - 6주 인턴으로 신규 입사자 정보 관리와 ERP 운영을 지원
- 2020.08 정보처리기사
- 2021.09 ~ 2022.04 · 1120h  
**코드스테이츠 - AI 부트캠프 (7기)**
  - 데이터 분석 · AI · 자연어 처리 통합 과정
  - KoBERT 뉴스 보정 기업 협업 프로젝트
- 2022.05 ~ 2022.06 · 3주  
**코드스테이츠 - AI 심화 NLP 과정**
  - PyTorch로 BERT를 추가 학습시켜 문장 유사도(STS) 계산
- 2022.09 ~ 2023.03  
**비상교육 - AI 연구개발 Cell**
  - 실제 회사 데이터로 AI 서비스 PoC 2개 1인 개발 (이탈 고객 예측, 질문-답변 검색)
  - 대표이사 앞에서 시연
- 2022.12 빅데이터분석기사
- 2023.10 SQLD

2025 ~ 현재

- 2025.03 ~ 2025.08 · 960h  
**KOSA 생성형 AI 과정 - KOCRUIT**
  - LangGraph와 FastAPI 서버를 처음부터 끝까지 구현
  - 최종 프로젝트 팀장 · 과정 내 1위
- 2025.08 ~ 2025.10  
**KOSA Spec-up - K-Bridge**
  - 수출입 통관 규정 AI 분석 4인 팀 프로젝트
  - 수입 요건 분석 담당
- 2025.09 OPIc 영어 IH
- 2026.03 ~ 현재  
**KOSA - AI 교육 보조강사**
  - 직업훈련교강사 보수교육에서 수강생 12~20명의 실습 지원
  - 담당 강의 16개 (Spring AI · MCP · LangGraph · Claude Code 등)
  - 수강생 코드의 오류를 함께 찾고 기술 질문에 답변
- 2026.06 ~ 2026.08.25 · 320h  
**[NIPA·NVIDIA] GPU 가속 기반 AI Agent 엔지니어 과정**
  - LangGraph · 고급 RAG · MCP · 에이전트 하네스
  - 프로젝트 QMesh
- 2026.07 정보보안기사 필기 합격 · AI-POT
- 2026.08 NVIDIA DLI 인증 5개 (RAG Agents · LLM 앱 · Diffusion 등)
- 2026.08 ~ 2026.09.30 · 진행 중  
**[Google] 2026 Google Cloud Study Jam H2**
  - Professional Agentic Architect Certification 강의 중심으로 수강 중

#A2A #MultiAgent #ProtocolDesign #HumanInTheLoop

연결 대상 3종도 모두 직접 만든 1인 프로젝트



실선은 A2A 직접 호출, 점선은 허브 자리(설계)입니다. 허브는 비워 두고 계약만 먼저 고정했습니다.

POST /a2a/skills/assess-loan · request\_chain\_id: CHAIN-LOAN-a0639920  
→ FinAllQ LTV 판정 → InsuQ 담보 보험 검증 ← decision: conditional · 1.3s  
2026-08-24 실측. 5억 신청 · 담보 인정액 3억 → 보장 부족으로 조건부

**구현** FastAPI · httpx · pydantic (Python), Spring MVC (Java). A2A 전용 SDK 없이 약속(JSON Schema)을 직접 구현했습니다.

**약속** Agent Card 3종 · Task 스키마 13종 · request\_chain\_id · Idempotency-Key

### ◆ 문제

보험 · 금융 · 설비 보전 에이전트를 만들고 나서 이것들을 엮어 보고 싶었습니다. 세 시스템을 각자 다른 회사라고 가정하니, 한쪽에서 온 요청을 **어디까지 믿고 무엇까지 보여 줘야 하는지**부터 막혔습니다. MCP는 AI가 자기 도구를 쓰는 방식이라, 다른 회사 AI에게 일을 맡길 때 필요한 신원 확인과 사람의 승인 대기는 따로 설계해야 했습니다.

### ◆ 구현한 시나리오

공장에서 설비가 고장 나면 **MaintQ**가 **InsuQ**에서 약관 조항을 근거와 함께 받아 오고, 부품을 발주하면 대금 출금 요청이 **FinAllQ** 결재함에 도착합니다. 설비를 담보로 대출을 신청하면 은행 AI가 다시 보험사 AI에 담보 보험을 확인합니다. 이 이야기에 나오는 연결 7가지를 목킹 없이 실제 시스템끼리 하나씩 끝까지 돌려 확인했습니다.

### ◆ 제가 내린 결정

#### 신원

#### 보낸 회사와 자료 주인을 따로 확인합니다

요청을 보낸 회사(Actor)와 그 요청이 다루는 자료의 주인(Subject)을 나누고 나서야, 조회 · 심사 · 돈 이동 순으로 허락 범위를 좁힐 수 있었습니다.

#### 승인

#### 돈이 움직이면 사람이 세 번 승인합니다

공장 팀장 · 공장 재무팀 · 은행 결재를 거칩니다. AI는 초안까지만 쓰고, 승인할 권한 자체가 없습니다.

#### 약속

#### 약속에 없는 값은 오류로 알립니다

스키마에 없는 값은 502로 돌려줍니다 - 조용히 넘기면 틀린 값이 다음 회사까지 흘러가기 때문.

01-1 FinAllQ AI 비서인데 생성형 AI를 쓰지 않았다

QMesh 연결 에이전트 · 은행·증권 금융 비서

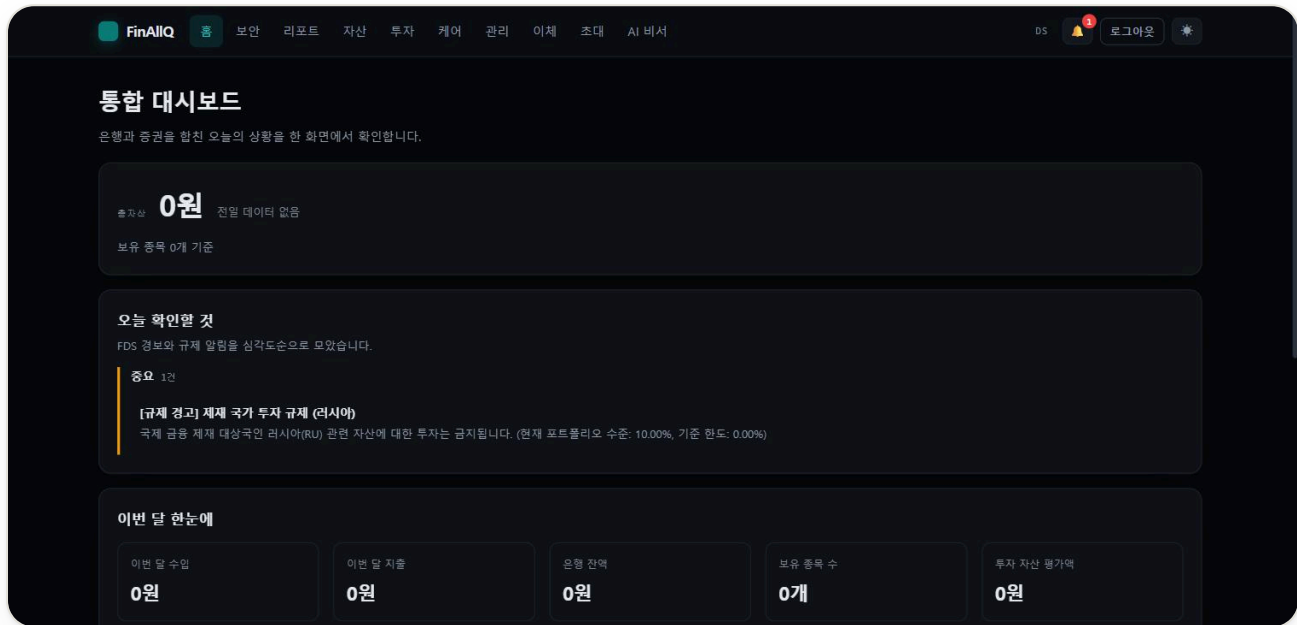
2025.10 ~ 진행 중 · 개인 1인

Spring Boot 3 + FastAPI + React 19 · PostgreSQL · Redis

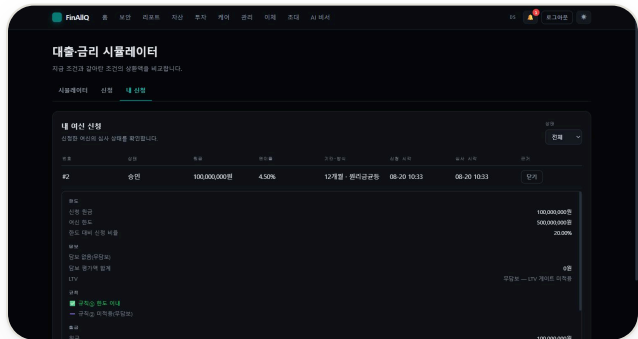
🔗 상세 페이지

#규칙기반 #FDS #직무분리 #2FA

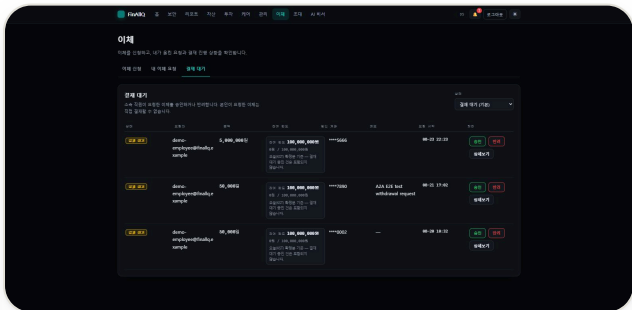
아래 화면은 모두 배포 환경(Vercel + Cloud Run)에서 찍은 캡처입니다



통합 대시보드. 상단 규제 경고는 포트폴리오 비율을 계산해 기준값과 비교한 결과입니다.



여신 심사 근거. 한도 · LTV · 규칙 판정



기업 이체 결재함. 요청자별 1일 한도 사용액

◆ 문제

은행·증권을 한 화면에서 다루는 금융 비서는 이상거래 판정이나 이체 차단처럼 나중에 이유를 설명해야 하는 결정을 내립니다. 감사 기록에 «AI가 그렇게 판단했습니다»라고 적을 수는 없습니다.

◆ 주요 기능

- 01 통합 대시보드  
은행과 증권을 합산하고, 규제 경고는 비율을 계산해 띄웁니다.
- 02 여신 심사 근거 카드  
심사 때와 같은 판정 로직을 재사용해 화면과 심사가 갈라지지 않습니다.
- 03 여신 ↔ 이체 연결  
서버가 «출금 가능»으로 판정할 때만 버튼이 나오고, 계좌는 사람이 입력합니다.
- 04 기업 이체 결재 (직무 분리)  
신청한 사람에게는 취소 버튼만 있고 승인 버튼이 없습니다.
- 05 FDS 고위험 → 2FA 승격  
결재가 끝나도 이상거래 탐지가 다시 평가해 추가 인증(TOTP)을 요구합니다.
- 06 스미싱 탐지  
키워드 목록 대신 모델로 판정하고, 위험 단어를 근거로 보여 줍니다.
- 07 AI 비서  
범위 밖 질문은 지어내지 않고, 결과를 못 받은 기능은 배너로 알립니다.

모델 IsolationForest (이상거래) · TF-IDF + LogisticRegression (스미싱). 생성형 AI 호출은 0건입니다(전수 검색).

도구 MCP Hub 도구 20종을 질의 키워드 점수로 최대 3개까지 고릅니다.

# 01-1 FinAllQ · 설계에서 내린 결정

## LLM을 쓰지 않은 이유

측정 기준일 2026-09-08

#감사가가능성 #IsolationForest #안전장치

이 서비스가 하는 일은 결국 «어떤 도구를 어떤 순서로 부를까»입니다

### 결정 공간

#### 선택지가 닫혀 있었습니다

도구는 20종으로 정해져 있고 하는 일도 고정돼 있습니다. 닫힌 문제에 LLM을 넣으면 같은 질문에 같은 답이 보장되지 않고, 왜 그 도구를 골랐는지 설명할 수 없습니다. 그래서 질의와 도구의 키워드를 맞춰 점수가 높은 순으로 최대 3개를 고르게 했습니다.

### 감사

#### 금융은 근거를 남겨야 합니다

규칙은 어떤 입력이 어떤 규칙을 탔는지가 코드에 그대로 남아, 판정 근거를 감사 기록으로 옮길 수 있습니다. 답변에 실릴 수 있는 항목도 목록으로 정해 두었습니다.

### 모델

#### 규칙이 안 되는 곳에만 모델을 썼습니다

- 이상거래는 IsolationForest - 정상 패턴의 경계를 사람이 기준값으로 정할 수 없기 때문.
- 스미싱은 TF-IDF + LogisticRegression - 문구 변형이 끝이 없어 키워드 목록은 바로 뚫리기 때문.

**QMesh에서의 역할** - 공장이 보내는 출금·대출·정산 요청을 받는 은행입니다. 시가 «승인»이라고 답해도 대출 상태는 «심사 중»으로 남고, 사람이 따로 승인합니다.

### ◆ LLM 대신 공들인 안전장치 4가지

| 안전장치              | 하는 일                                                        |
|-------------------|-------------------------------------------------------------|
| ① 권한별 도구 노출       | 권한 밖 도구는 도구를 고르는 단계에 아예 올라가지 않습니다.                          |
| ② 부작용 도구 자동 실행 금지 | «송금해줘»라고 해도 시스템이 알아서 돈을 움직이지 않게, 부작용이 있는 도구는 자동 선택에서 뺐습니다.  |
| ③ 송금 흐름 FDS 필수 통과 | 송금 계열 흐름은 이상거래 점수를 건너뛸 수 없게 했습니다. (지금은 발동하지 않습니다. 아래 한계 참고) |
| ④ 출력 항목 목록        | 도구가 무엇을 돌려주든 목록에 등록된 항목만 답변에 실어, 민감정보가 새는 길을 막았습니다.         |

**LLM으로 바꿀 기준도 미리 정했습니다.** 도구 매칭 실패가 눈에 띄게 늘거나 도구가 20종을 크게 넘어 키워드가 자주 부딪치면, 도구를 고르는 부분만 바꿉니다. 그때도 안전장치 4가지는 그대로 둡니다.

### ◆ 한계 - 아직 안 된 것도 같이 적습니다

#### FDS 필수 통과는 자리만

대상 도구 목록이 비어 있어 지금은 발동하지 않습니다. 코드 주석과 백로그에 적어 두었습니다.

#### 재학습 파이프라인 없음

학습 데이터가 코드에 고정돼 있습니다. 사용자마다 달라지는 것은 기준선(30일 평균 이체액 등)뿐입니다.

#### 동의어·오타에 약함

도구를 키워드 부분 일치로 고르기 때 문입니다. 코드 맨 위 주석에 «LLM이 아니다»라고 적어 두었습니다.

# 01-2 InsuQ 근거 조항과 함께 답하는 약관 에이전트

QMesh 연결 에이전트 · 보험 약관 RAG

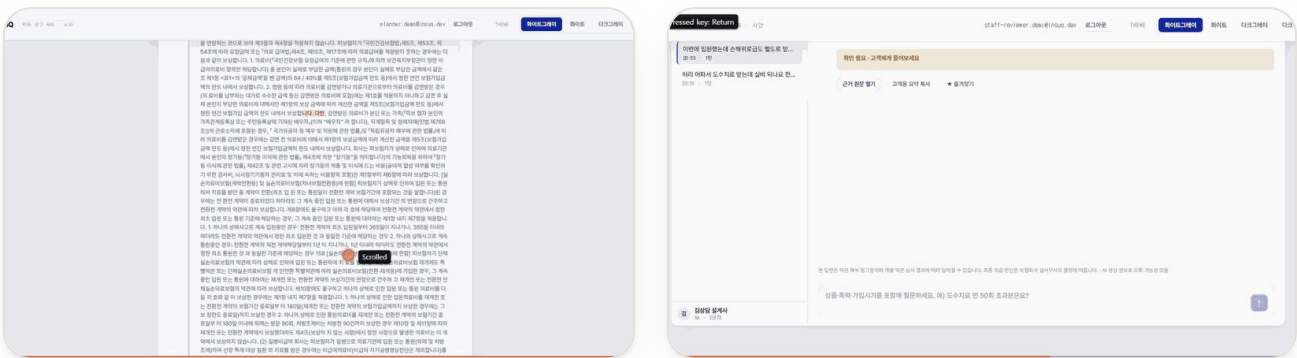
2026.07 ~ 진행 중 · 개인 1인

Spring Boot 4 + FastAPI/LangGraph · Qdrant · Next.js

[상세 페이지](#)

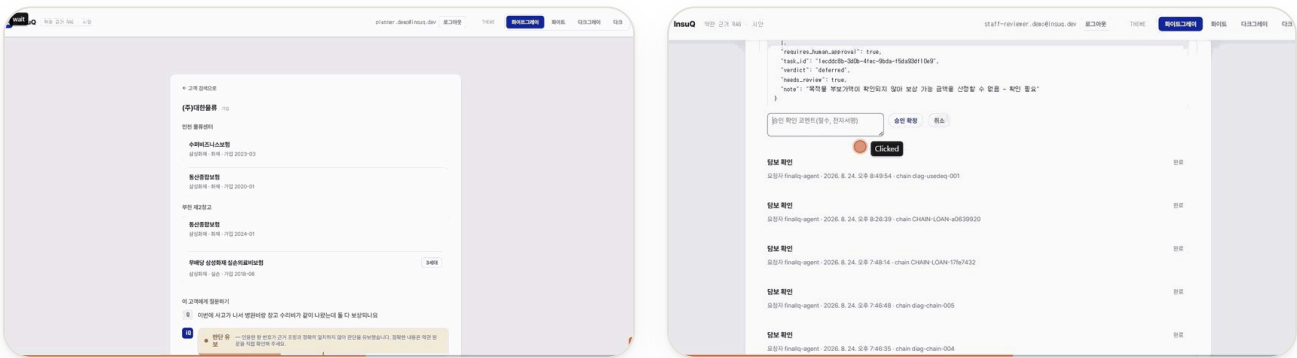
#RAG #근거인용 #거부게이트 #HumanInTheLoop

아래 화면은 모두 실제 서비스 캡처입니다



㉠ 근거 인용. 조항 원문과 함께 답합니다.

㉡ 거부 게이트. 근거가 없으면 거부합니다.



㉢ 되묻기. 정보가 빠지면 확인 질문을 냅니다.

㉣ 청구 승인. 심사역이 전자서명해야 완료됩니다.

|       |                                                                                  |
|-------|----------------------------------------------------------------------------------|
| 모델    | 생성 gpt-4.1-mini · 평가 gemini-3.5-flash · 임베딩 nemotron-3-embed-1b                  |
| 도구    | Qdrant 검색 · LangGraph · A2A 스킴 6종 (lookup-clause, verify-collateral-insurance 등) |
| QMesh | 공장의 약관 질문과 설비 처분 통지를 받고, 은행이 대출을 심사할 때 담보 보험을 확인해 줍니다.                           |

## ◆ 문제

보험금 판정이 틀리면 곧 누군가의 금전 손해입니다. 보험설계사는 고객 앞에서 **근거가 되는 약관 조항을 직접 보여 줄 수 있어야** 하는데, «지금 가능/불가»만 알려 주는 답으로는 그럴 수 없습니다.

## ◆ 해결 방법 - 답변 형식을 코드로 고정했습니다

|    |                                 |
|----|---------------------------------|
| 판정 | 가능성 높음 · 낮음 · 판단 보류 중 하나로만 냅니다. |
| 근거 | 약관 조항 원문을 붙이고, 파트와 조 번호로 대조합니다. |
| 확인 | 사람이 확인할 사항을 함께 적습니다.            |
| ✕  | «지금 가능합니다» 같은 단정은 판단 보류로 낮춥니다.  |
| ✕  | 근거가 없으면 «약관에서 확인 불가»로 거부합니다.    |

## ◆ 방어선 두 개

- **LLM 호출 전:** 검색 결과가 없거나 점수가 모자라면 모델을 부르지 않습니다. 필요한 정보가 빠진 질문에는 확인 질문을 내고, 이때도 LLM을 부르지 않습니다.
- **LLM 호출 후:** 인용이 진짜인지 검증하고, 단정 표현은 판단 보류로 낮춥니다.

두 방어선 모두 프롬프트 지시로 두지 않고 코드로 동작합니다.

# 01-2 InsuQ · 설계에서 내린 결정

## 안전장치를 실행 경로에 두기

측정 기준일 2026-09-09 · 실손보험 27문항

#검색설계 #단정금지 #캐시 #기각한시도

설계사가 일하는 순서대로 찾습니다

### 검색

#### 작게 찾고 크게 답합니다

고객이 가입한 상품으로 먼저 좁혀 찾습니다. 조·항 구조를 살려 나눈 뒤 검색과 순위는 항 단위로 하고, 조 단위로 넓히는 것은 답을 만들기 직전에만 합니다. 찾은 조문이 다른 조문을 참조하면 같은 파트 안에서 깊이 제한을 두고 따라갑니다.

### 인용 대조

#### 조 번호에 파트까지 맞춥니다

한 약관 안에서 제1조가 보통약관·특약 등 여러 파트에 동시에 있습니다(한 상품에서 3곳 확인). 조 번호만 맞추면 모델이 다른 파트의 같은 조 번호를 지어내도 걸러지지 않기 때문입니다.

### 단정 금지

#### 조사 하나로 샌 구멍

«지금 가능합니다»는 잡는데 «지급이 가능합니다»는 통과한 적이 있습니다. 고치면서 탐지 범위만 넓히지 않고 잘못 잡는 비율도 함께 켜했습니다(저장된 답변 287건 중 새로 걸린 것 0건).

### 캐시

#### 캐시가 안전장치를 우회하지 못하게

캐시 키에 상품 필터·모델·프롬프트 본문·인덱스 버전을 모두 넣었습니다. 상품 필터를 빠뜨리면 «다른 고객 계약을 인용하지 않는다»가 캐시로 뚫리기 때문입니다.

### ◆ 측정 후 기각한 시도

| 시도                | 젠 결과                                                          |
|-------------------|---------------------------------------------------------------|
| 하이브리드 검색 (BM25)   | 정답 조항 상위 5개 포함률이 0.81에서 0.79로 떨어져, 제 가설이 틀렸습니다.               |
| cross-encoder 리랭커 | 품질은 가장 좋았지만 응답 시간 중간값이 98.2초였습니다.                             |
| 저가형 생성 모델         | 거부 정확도는 1.0000으로 같았지만, 답할 수 있는 질문을 거부한 비율이 0에서 0.1852로 올랐습니다. |

실험 67건을 가설·측정·판단 형식으로 남겼고, 기각한 것도 지우지 않았습니다. 지우면 다음 사람이 같은 가설을 다시 세우기 때문입니다.

**사고도 구조로 바꿨습니다.** 개발 환경에 남은 인증 정보 때문에 운영 인덱스(4,233청크)가 지워진 적이 있습니다. 그 뒤로는 새 버전을 채우고 검증을 통과했을 때만 교체해서, 중간에 멈춰도 이전 버전이 남습니다.

### ◆ 한계

#### AI 채점 칸이 비어 있음

채점 모델이 게이트웨이 계정 폐기로 사라졌습니다. 사람이 채점한 24문항이 남아 있어 다시 맞출 수 있습니다.

#### 화재보험 수치는 따로 읽어야 함

66문항 중 52문항을 채점해 상위 5개 포함률 0.6346입니다. 실손과는 약관도 질문도 달라 나란히 비교할 수 없습니다.

# 01-3 MaintQ 설비 진단부터 부품 발주 초안까지

QMesh 연결 에이전트 · 제조 설비 보전

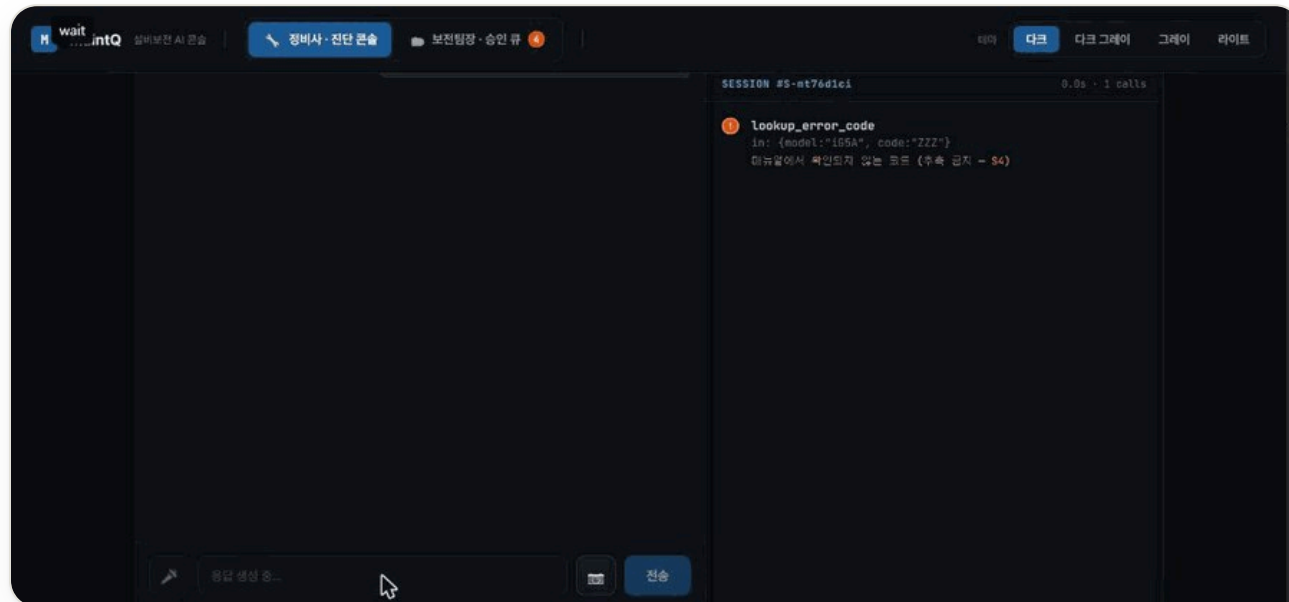
2026.07 ~ 진행 중 · 개인 1인

Python FastAPI + MCP + PostgreSQL(pgvector) + Next.js

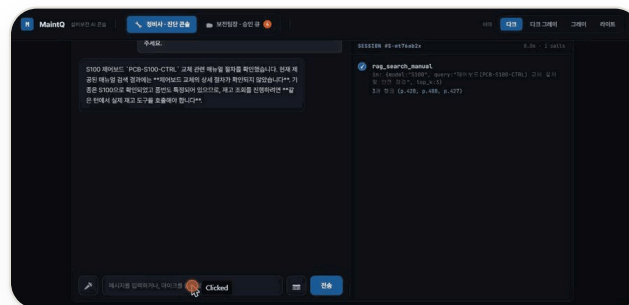
[상세 페이지](#)

#MCP #AgentLoop #HumanInTheLoop #설비보전

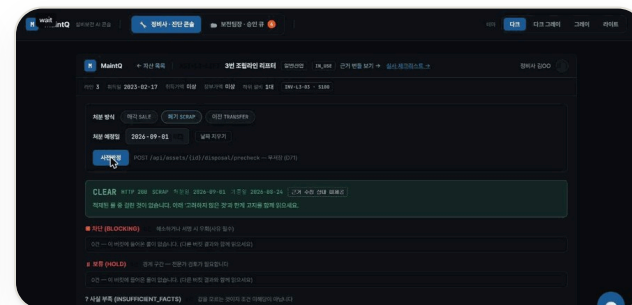
화면은 공개 매뉴얼과 생성한 시드 데이터로 찍었습니다. 실사용자는 없습니다



미지 에러코드. 카탈로그에 없는 코드는 지어내지 않고 A/S 경로를 안내합니다.



재고 0 → 호환 대체품



처분 사전판정. 사실이 모자라면 판정하지 않습니다.

## ◆ 문제

공장 설비(인버터·PLC)에 에러가 뜨면 정비사는 PDF 매뉴얼을 10~30분씩 뒤지고, 부품은 전화와 엑셀로 주문합니다. 기존 설비관리 시스템(CMMS)은 이력·재고·주문을 기록할 뿐, 왜 에러가 났고 어떤 부품이 필요한지는 판단하지 못합니다.

## ◆ 주요 기능

### 01 미지 에러코드

에러코드는 검색(RAG)이 아닌 정확 조회로 찾고, 없으면 «모른다»고 답합니다.

### 02 재고 0 → 호환 대체품

호환이 확인된 부품만 제안하고, 견적은 비교해 보여 주기만 합니다.

### 03 반복 고장 → 발주 보류

30일 안에 같은 에러가 3번 나면 근본 원인 점검으로 바꿉니다.

### 04 처분 사전판정

처분일 같은 사실이 빠지면 «사실 부족»으로 답합니다.

### 05 처분 근거 번들

법령 · 룰 · 평가값 · 계약 · 사실을 묶어 해시로 곁합니다.

### 06 법정 기한 · 위험등급

산출식을 보여 주고 «자동 반영 안 됨»을 알립니다.

### 07 지출 성격 분류

경계 사례는 «판단 보류 - 전문가 검토 필요»로 답합니다.

도구

MCP 도구 22종 (기본 7 + 확장 15) · 쓰기 3종은 초안만 만듭니다

모델

Gemini 2.5 Flash · GPT-OSS:120B (통제 비교) · 자체 Agent Loop

# 01-3 MaintQ · 설계에서 내린 결정

## 합계에 가려진 위험한 실패를 따로 셧습니다

측정 기준일 2026-09-11

#오특정 #통제비교 #도구경계 #신뢰구간

틀린 부품을 확신하면 엉뚱한 발주로 이어집니다

두 모델의 부품 특정 정확도가 45.6%와 51.0%로 비슷해서 차이가 없다고 넘길 뻔했습니다. 안을 열어 보니 한쪽은 틀린 부품을 자신 있게 골랐고(오특정), 다른 쪽은 답을 내지 않았습다(미특정). 같은 실패로 합치면 더 위험한 쪽이 더 좋아 보여서, 두 실수를 따로 세고 지시문만 바꿔 비교했습니다.

| GPT-0SS:120B · 20문항 · 각 120세션 | 변경 전  | 변경 후  | 판정                    |
|-------------------------------|-------|-------|-----------------------|
| 부품 특정 정확률 (합계)                | 71.1% | 88.9% | 구간이 겹치지 않음 (경계선)      |
| ↳ 오특정 (틀린 부품을 확신)             | 16.7% | 1.1%  | 구간이 겹치지 않음 - 실제로 고친 것 |
| ↳ 미특정 (답을 안 냄)                | 12.2% | 10.0% | 구간이 겹침 - 주장하지 않음      |
| 근거 페이지 인용률                    | 99.1% | 96.3% | 소폭 하락 - 구간이 겹침        |
| 안전 경고 통과                      | 92.6% | 89.8% | 소폭 하락 - 구간이 겹침        |
| 모르는 에러코드를 지어낸 비율              | 0.0%  | 0.0%  | 양쪽 모두 목표 달성           |

몇 번 돌려야 믿을 수 있는지부터 셧습니다. 정답률이 50% 안팎인 문항은 20번을 돌려도 95% 신뢰구간 폭이 40%p였고, 같은 조건의 10번짜리 묶음 둘이 인용률에서 12%p 어긋나기도 셧습니다. 그래서 위 비교는 각 120세션으로 셧렸습니다.

### 도구 경계

#### 조회와 검색을 다른 도구로 나췌습니다

도구 22종 각각에 «언제 쓰고 언제 쓰면 안 되는지»를 적었습니다. 정확히 맞아야 하는 에러코드 조회에 검색을 쓰면 «그럴듯한 다른 코드»가 올라오기 때문에 조회 도구를 따로 두었습니다. 실패도 오류로 던지지 않고 정해진 상태값으로 돌려줘, 에이전트가 다음 행동을 고를 수 있게 셧습니다.

### 쓰기

#### AI는 초안만, 신원은 서버가 넣습니다

쓰기 도구는 3종이고 셧 다 초안만 만듭니다. 승인 · 반려 · 서명은 사람 전용 화면에서만 일어납니다. 요청한 사람의 신원도 도구에 넘기는 값으로 받지 않고 서버가 넣어서, AI가 신원을 꾸며 낼 길이 없습니다.

### ◆ 한계

#### 부품 특정 목표 미달

gemini-2.5-flash 측정(08-17)에서 40.0%(18/45)로 목표 90%에 못 미쳤습니다.

#### 인용 · 안전 경고 미달

같은 측정에서 인용률 90.7% (49/54), 안전 경고 70.4%(38/54)입니다.

#### 현장 효과는 못 쯤

«고장에서 발주까지 30분 이상 → 5분»은 가설 지표로만 적어 두었습니다.

**QMesh에서의 역할** - 일이 시작되는 공장입니다. 은행과 보험사에 요청을 보내기만 하고, 받는 요청은 설계상 두지 않습니다.

# 02 SecureAI Engine

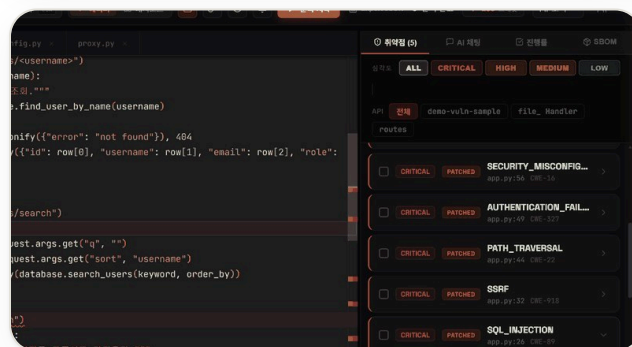
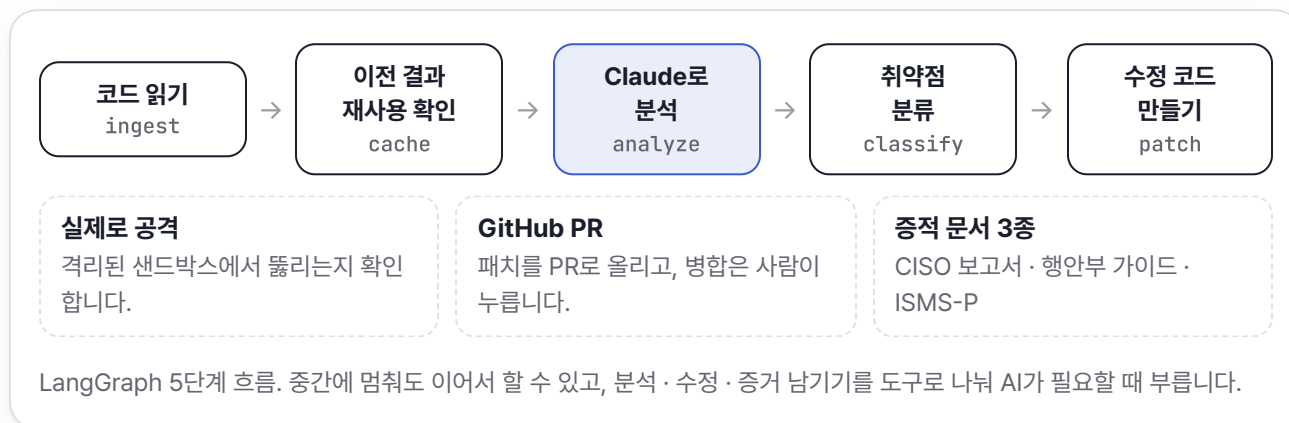
AI 기반 코드 보안 분석 플랫폼

★ AI AGENT 대표작

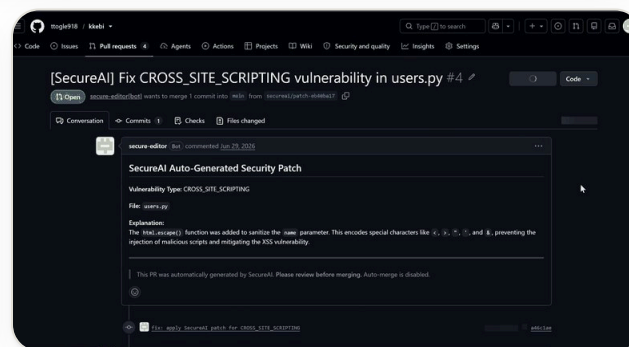
~2026.07 (Sprint 0~30) · 개인 1인  
Claude Code 멀티 에이전트 오케스트레이션으로 개발  
[GitHub](#) [데모 영상](#)

#TrustworthyAI #DAST교차검증 #탐지율개선 #DevSecOps

모두의 창업 · 스파크클로 창업 프로그램 출품



취약점 목록. 심각도별로 고칠 코드까지 보여 줍니다.



패치 PR. 병합은 사람이 누릅니다.

## ◆ 문제

팀 프로젝트에서 AI로 코드를 쓰다 보니 .env 파일이 깃에 올라가고, API 키가 코드에 그대로 박히는 일이 반복됐습니다. **AI가 쓴 코드를 그대로 믿으면 안 되겠다**고 생각해 보안 분석 도구를 만들기 시작했습니다.

## ◆ 해결 방법

- **실제로 공격해 보고 확인:** 찾은 취약점을 격리된 실험 환경(샌드박스)에서 실제로 공격해 보고, 정말 뚫리는지로 증명했습니다.
- **DB는 서버 API로만:** AI가 DB를 바로 조회하게 하면 SQL 인젝션을 막는 파라미터 바인딩을 쓸 수 없었습니다. 조금 돌아가더라도 서버 API를 거치게 바꿔 DB에 닿는 경로를 줄였습니다(ADR-016).

## ◆ 설계에서 신경 쓴 것

- **역할을 나눈 AI 개발:** 총괄 · 기획 · 개발 · 리뷰 · 문서 역할의 Claude Code 에이전트를 동시에 돌려 혼자서 Sprint 0~30을 진행했습니다.
- **운영에 필요한 것까지:** 모니터링(Prometheus · Grafana · Jaeger), 진행 상황 실시간 전송(SSE + Redis), 네트워크 4개 분리, JWT HttpOnly.
- **쓰는 곳을 넓힘:** VSCode 확장은 코드 옆에 취약점을 표시하고, 안드로이드 앱(Kotlin · Compose · 푸시 알림)도 같은 서버에 연결했습니다.

**모델** Claude Sonnet 4.6 (제품) · Gemini 2.5 Flash (가이드라인 비교 실험)

**도구** LangGraph · Docker 샌드박스 · FastAPI · Redis · Prometheus · Grafana · Jaeger

## 02 SecureAI Engine · 고민한 문제

# 오탐을 유형별로 나눠 줄인 과정

OWASP BenchmarkJava 1.2beta · 2026-07-03 ~ 07-04 측정

#오탐분석 #가이드라인 #OWASPBenchmark

탐지율은 올렸고, 오탐은 과제로 남았습니다

### ◆ 처음 분석에서 생긴 일

안전한 React 화면 코드를 XSS 취약점으로, 테스트용 가짜 데이터를 '심각'으로 잡는 일이 많았습니다. 유형별로 나눠 보니 원인이 달라서 따로 고쳤습니다.

- 프레임워크가 막아 주는 패턴은 프레임워크 규칙을 알려 줬습니다.
- 테스트 파일은 분석 전에 미리 봤습니다.
- 보안이 아닌 코드 품질 문제는 따로 분류했습니다.

### ◆ 가이드라인은 길수록 좋지 않았습니다

보안 지식을 자세히 넣을수록 좋을 줄 알고 6만 자가 넘는 가이드라인을 넣었더니, 아무것도 넣지 않았을 때보다 오탐이 크게 늘었습니다. 무엇을 찾아야 하는지만 남기자 탐지율이 올라갔습니다.

| Gemini 2.5 Flash · 330케이스 | 크기        | 탐지율   | 오탐률   |
|---------------------------|-----------|-------|-------|
| 가이드라인 없음                  | 0         | 47.3% | 23.6% |
| 옛 가이드라인                   | 63,527자   | 60.9% | 43.1% |
| 1차 정리 - 설명을 걷어냄           | 기록 없음     | 54.6% | 23.6% |
| 2차 정리 - 찾을 항목만 남김         | 약 14,000자 | 81.6% | 30.9% |

### ◆ 정한 가이드라인으로 제품 모델을 돌린 결과

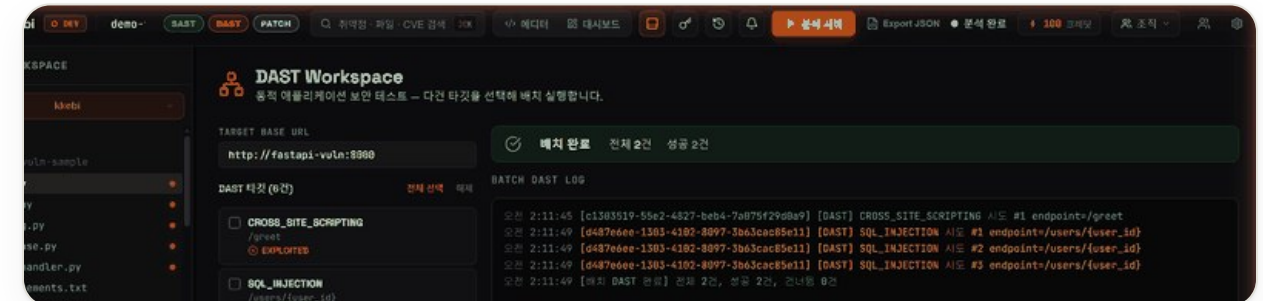
# 96.6%

탐지율 · 515 / 533 · Claude Sonnet 4.6 · 961케이스

# 27.1%

오탐률 · 116 / 428 · 남은 과제

오탐이 높은 유형은 trustbound 0.563 · securecookie 0.548 · crypto 0.460입니다.



DAST 검증. 찾은 취약점을 실제로 공격해, 뚫리면 EXPLOITED로 표시합니다.

**프로젝트의 역할을 다시 정했습니다.** 개발 도중 훨씬 강력한 모델이 나와 계속할 의미가 있나 싶었습니다. 그래서 이 프로젝트를 사람이 쓰는 프로그램으로 다시 정의했습니다. 판단의 근거를 사람에게 보여 주고, 사람이 확인해 고치게 돕습니다.

## ★ MORE PROJECTS ★

03

2026.06 ~ 진행 중 · 개인 1인

### KeyLens

개인 개발자용 자격증명 관리 도구 (키지기)

#LocalFirst #AES-256-GCM #OCR분류 #OpenSource

#### ◆ 문제

보조강사로 일하며 수강생들이 API 키를 코드에 그대로 두는 걸 자주 봤습니다. 막힌 곳은 노선의 여러 ID처럼 모양이 똑같은 값이었습니다. 값만 봐서는 무슨 키인지 알 수 없었습니다.

#### ◆ 해결

- 앞부분으로 알 수 있는 키(sk- · ghp\_ · AKIA)는 바로 판별하고, 애매한 값은 화면 캡처를 OCR로 읽어 옆 이름표와 주소 구조로 구분합니다. 단서가 엇갈리면 «확인 필요»로 남깁니다.
- 서버 없이 내 컴퓨터에만 저장합니다(Argon2id + AES-256-GCM). SQLite에서 지운 데이터도 덮어쓰도록 설정했습니다.
- YAML 파일 하나로 새 서비스를 추가합니다(현재 10종).

★ 2026 오픈소스 개발자대회 출품. v0.5.1을 MIT 라이선스로 공개했습니다.

↗ [GitHub](#) ↗ [다운로드](#) ↗ [데모 영상](#)

04

2026.08 ~ 09 · 개인 1인

### SpendQ

AI 에이전트가 알아서 구매 · 역경매 + 조건부 결제

#x402 #A2A #Solana #Escrow #Gemini

#### ◆ 문제

x402는 AI 에이전트가 돈을 내는 사실상의 표준이지만, 파는 쪽이 값을 정하면 사는 쪽은 내거나 말거나 둘 중 하나입니다. 흥정도, 판매자 간 경쟁도, 결과가 나쁠 때 돌려받을 방법도 없습니다.

#### ◆ 해결

- 역경매: 판매자 AI들이 가격과 납기를 적어 응찰하고(HTTP 402), 정한 규칙으로 낙찰자를 고릅니다.
- 에스크로: 돈을 블록체인 금고에 맡겨 두고, 검사를 통과해야 지급하고 실패하면 환불합니다.
- 지출 한도는 AI 지시문에 두지 않고 블록체인 계정에 걸었습니다. 앱을 건너뛰고 직접 보낸 한도 초과 거래도 체인이 거절했습니다.

★ 기본 검사만으로는 불량 18건 중 15건, Gemini가 고른 검사를 더하니 18건을 모두 잡았습니다.

↗ [라이브 데모 \(devnet\)](#)

개발 방식

개인 1인 · Claude Code CLI · 8개 레포

### AI 하네스 엔지니어링

8개 프로젝트에 같은 규칙으로 적용한 AI 작업 관리 틀

#Harness #SubAgent #Hooks #HumanInTheLoop

#### ◆ 문제

코딩 AI가 계획에 없던 기능을 끌어오고, 테스트가 실패하면 코드 대신 정답 파일을 고쳐 통과시키고, 검토만 맡긴 AI가 코드를 직접 고쳤습니다.

#### ◆ 해결

- 막는 방법을 지시문(skill) · 도구 권한(setting) · 코드(hook) 세 단계로 나누고, 위험이 큰 프로젝트일수록 더 강하게 막았습니다.
- 검토 담당 AI에게는 읽기 도구만 줘서 고칠 방법이 없게 했습니다. 채점용 정답 파일 쓰기는 hook이 막습니다.
- 구현 · 테스트 · 검토 · 커밋은 자동으로 흘러가고, 마지막에 사람 체크리스트에서 멈춥니다.

★ hook이 지금도 작동하는지 돌려 보니 3개 중 2개가 한 번도 실행된 적이 없었습니다. || exit 0이 오류를 가리고 있어서 고친 뒤, 위반 사례를 넣어 잡아내는지 확인했습니다.

## ★ MORE PROJECTS ★

### 05 K-Bridge

2025.08 ~ 10 · 팀 4인 (기여 25%)  
요건 분석 · 요건-판례 교차 검증

수출입 품목 번호(HS코드)로 규제를 자동 분석하는 AI · #RAG #LangGraph #CrossValidation

요건 하나만 틀려도 화물이 묶이는데, 언어 모델은 없는 규정도 그럴듯하게 만들어 냈습니다. 그래서 성능보다 틀린 답을 걸러내는 게 먼저라고 봤습니다. **제 담당**은 미국 공공 데이터 API(FDA · EPA 등)와 공식 웹페이지로 한정된 검색으로 요건을 모으고, 팀원이 분석한 미국 세관 판례와 교차 검증해 신뢰도 등급을 붙이는 일이었습니다.

★ 팀 전체: 흐름 6단계(LangGraph) · 연동한 규제 기관 9곳 · 미국 품목 분류표 30,067건. 팀 과제로 끝나 실제 효과는 재지 못했습니다.

↗ [GitHub](#)

### 06 KOCRUIT

2025.06 ~ 07 팀 프로젝트 · 팀장 (기여 40%) · 과정 내 1위  
2025.09 ~ 이어서 개선 중

AI Agent 기반 기업용 채용 관리 시스템 · #LangGraph #MSA #ServiceBoundary #TeamLead

- 합격 · 불합격은 AI가 정하지 않습니다. AI는 점수와 근거를 내고, 최종 판단은 사람이 합니다.
- **개선 중** AI가 88점을 줬는데 DB에는 불합격으로 남았습니다. LangGraph 상태 스키마에 키가 없어 노드 반환 값이 버려진 것이라, 상태 키를 검사하는 계약 테스트를 추가했습니다.
- **개선 중** 비동기 핸들러 안의 동기 LLM 호출이 서버를 멈춰, LLM 요청 중 헬스체크가 17.05초 걸렸습니다. 0.02초로 줄이고 AST 스캐너로 재발을 막았습니다.

★ 서류 평가 AI 호출 9회 → 4회, gpt-4o 9곳 중 8곳을 4o-mini로 교체했습니다. 음성 전사를 stt-service로 분리해 AI 서버 이미지를 3.6GB → 2.15GB로 줄였습니다.

↗ [GitHub \(팀 프로젝트\)](#) ↗ [PPT](#)

### 07 비상교육 · 질문-답변 검색

2022.12 ~ 2023.03 · 1인 개발  
대표이사 시연

#SBERT #NER #개인정보익명화

강사가 없을 때는 질문 답변이 늦어졌고, 게시판 원본 데이터에는 이름 · 주소 · 전화번호가 섞여 있었습니다. SBERT/KoBERT를 추가 학습시켜 새 질문과 비슷한 기존 질문 · 답을 찾아 주는 파이프라인을 만들고, 정규표현식과 NER을 조합해 개인정보를 가렸습니다(2주 동안 예외 사례를 반복 해결).

★ PoC라 익명화를 하지 않아도 됐지만, 데이터를 안전하게 만드는 일이 먼저라는 기준이 이때 생겼습니다.

### 08 비상교육 · 이탈 고객 예측

2022.09 ~ 2022.12 · 1인 개발  
대표이사 시연

#DataPreprocessing #RandomForest #변수중요도

실제 서비스 데이터 10만여 건에서 약정 진행 중 고객 · 테스트 계정 · 로그인 기록 없는 고객을 걸러 내자 학습에 쓸 수 있는 것은 2천 건이 채 되지 않았습니다. RFM으로 고객 특징을 만들고 KMeans로 묶은 뒤, 이탈 · 연장 여부가 확정된 고객으로 정확도를 켜었습니다.

★ RandomForest 이탈 예측 85.3% · XGBoost 활동 저하 예측 89%. 변수 중요도로 무엇 때문에 떠나는지까지 설명했습니다.

## ★ FUTURE PLANS ★

믿고 맡길 수 있는 AI 서비스를 만드는 엔지니어를 목표로 합니다.

### 01

#### 안전한 Agent-Backend 통합 아키텍처

AI가 데이터에 직접 닿지 않고 백엔드라는 한 통로로만 오가게 해, 권한 확인이 한곳에서 이뤄지는 AI 서비스 구조를 만들고 싶습니다.

### 02

#### 필요한 곳에만 쓰는 AI

규칙으로 되는 일은 규칙에 맡기고, 맥락을 읽어야 하는 곳에만 AI를 넣는 서비스를 설계하고 싶습니다.

### 03

#### 안전하게 협력하는 Multi-Agent 시스템

회사가 서로 다른 AI끼리 어디까지 믿을지 정해 두고 자료를 주고받아, 사람이 여러 시스템을 오가며 확인하던 일을 줄이는 연결 구조를 만들고 싶습니다.

# THANK YOU

읽어 주셔서 감사합니다. 연락 기다리겠습니다.

|           |                                                                                                                                 |
|-----------|---------------------------------------------------------------------------------------------------------------------------------|
| Email     | <a href="mailto:ttogle918@gmail.com">ttogle918@gmail.com</a>                                                                    |
| GitHub    | <a href="https://github.com/ttogle918">github.com/ttogle918</a>                                                                 |
| Portfolio | <a href="https://ttogle918.github.io">ttogle918.github.io</a>                                                                   |
| Blog      | <a href="https://zena1010.tistory.com">zena1010.tistory.com</a> · <a href="https://velog.io/@ttogle918">velog.io/@ttogle918</a> |